ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens APOGEE Insight (BAS management software) · Component type: **Software Application (SAR) - BMS management (legacy)** · Target SL = SL 3

Where to work	**APOGEE Insight** workstation (Windows): Insight **user accounts / operator access levels**, Windows accounts + BACnet access groups (e.g. "BACnet Export"), Insight audit/trend, secure download; field panels via **BLN/ALN** (Ethernet) and **P2/FLN**. Underlying **Windows Server** hardening applies (reference the Windows sheet).
Interfaces / ports	BAS management software; **BACnet/IP** (47808) + proprietary **P2/FLN** to field panels; Insight client/server; FTP (disable — use secure download); RDP for engineering. Legacy: no native protocol encryption.
Notes	SAR (software application) — legacy Siemens BAS management platform. **BACnet and P2 are unencrypted**: identity, crypto, and comms-integrity requirements are commonly met by a **firewall + VPN + strict segmentation** compensating control (a VLAN alone is NOT zone-boundary protection). Record the basis per requirement.
How to read	Read-only: review Insight accounts/access levels, audit, and the hosting Windows policy. Native how-to + external-tool validation + pass. Scans authorized; exploit/fuzz only in an isolated environment.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the APOGEE Insight database backup, the point database and user-account exports, and the application logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm every operator/engineer authenticates to **APOGEE Insight** (Insight accounts and/or Windows accounts) before workstation/field access; disable shared/auto-login; where legacy field access cannot authenticate, front it with an authenticating jump host (compensating). **Ext. tools:** Insight account review; attempt anonymous field access (isolated).	All access authenticated (Insight/Windows); no anonymous use.	
SR/CR 1.2	Software process & device identification & authentication	Confirm devices and software processes are identified/authenticated to the component. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software process & device identification & authentication verified individually.	
SR/CR 1.3	Account management	Manage Insight **operator access levels** and Windows/AD groups: create/modify/disable, least-privilege (view vs command vs configure vs admin), and control the "BACnet Export"/access groups; no shared logins. **Ext. tools:** Insight access-level + AD group review.	Accounts managed; least-privilege access levels; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (Insight/Windows) and unique device identity (BACnet instance, panel address); no reuse across the BAS. **Ext. tools:** User + BACnet device-ID review.	Unique user and device identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.5	Authenticator management	Enforce password policy via Windows/AD (length/complexity/expiry/history) for Insight/Windows accounts; change all factory/default passwords; manage lifecycle. **Ext. tools:** AD/secpol password-policy review.	Strong, managed authenticators; defaults changed.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Legacy BACnet/P2 have no native certificates. Confirm certificates on the compensating layer (VPN endpoints, HTTPS for any Insight web/reporting) are CA-issued and valid; record the VPN/firewall as the trust boundary where field crypto is unavailable. **Ext. tools:** openssl (VPN/HTTPS endpoints); cert review.	Valid certs on the compensating VPN/HTTPS layer; basis recorded.	
SR/CR 1.9	Strength of public key auth	Where TLS exists (VPN, Insight web/reporting), confirm strong ciphers/keys (TLS 1.2/1.3). Legacy field protocols rely on the compensating encrypted VPN tunnel. **Ext. tools:** testssl.sh (VPN/HTTPS); tunnel-cipher review.	Strong crypto on the compensating layer; field via VPN tunnel.	
SR/CR 1.10	Authenticator feedback	Confirm the Insight logon and any web/reporting logon mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm lockout on repeated failed logins (Windows/AD account lockout for Insight accounts) and that failures are recorded (Insight audit / Windows security log). **Ext. tools:** AD lockout policy; audit / Event Viewer review.	Failed logins locked out and logged.	
SR/CR 1.12	System use notification	Confirm the approved use-notification banner appears before access (Windows interactive-logon banner on the Insight server; login notice where the interface supports it). **Ext. tools:** GPO logon banner review.	Approved use notification presented before access.	
SR 1.13	Access via untrusted networks	Confirm Insight/field networks are reachable only from the trusted zone; remote access via **VPN** to a firewalled boundary (per the APOGEE IT infrastructure guidance); deny direct access from untrusted networks; split tunneling disabled. **Ext. tools:** Nmap (untrusted side); firewall/VPN rule review.	Access from untrusted networks denied/brokered; remote via VPN only.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm Insight **operator access levels** enforce view vs command vs configure; point/command rights bound to levels/groups; unauthorized commands (override, program) denied. **Ext. tools:** Access-level review; attempt unauthorized command (isolated).	Least-privilege authorization enforced.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control removable media on the Insight server (Windows device control); **disable FTP** and use secure download; no unmanaged media loads databases/updates. **Ext. tools:** GPO device-control review; confirm FTP disabled.	Removable-media use controlled; FTP disabled (secure download).	
SR/SAR 2.4	Mobile code	Restrict active/mobile code on the host: app allow-listing (AppLocker/WDAC), controlled Insight scripting/reporting content, no untrusted code execution. **Ext. tools:** AppLocker/WDAC policy; Insight content review.	Only trusted application code runs; untrusted mobile code blocked.	SAR-specific.
SR/CR 2.5	Session lock	Confirm Insight auto-logoff on inactivity and OS screen-lock; re-authentication required to resume. **Ext. tools:** Insight logoff config; GPO screen-lock.	Sessions lock/log off on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.6	Remote session termination	Confirm RDP/remote and Insight sessions time out and can be terminated by admin; clients logged off centrally. **Ext. tools:** RDP timeout; session review.	Remote sessions time out and are terminable on demand.	
SR/CR 2.7	Concurrent session control	Confirm concurrent Insight/client sessions are limited by license/policy; no shared concurrent privileged logins. **Ext. tools:** Insight/client session review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm Insight records operator commands and config changes with the user identity (Insight audit/activity log) plus the Windows security log; forward to the SIEM; actions attributable. **Ext. tools:** Insight audit log; Windows Event Viewer; SIEM forwarding.	Operator/config actions audited and attributable.	
SR/CR 2.9	Audit storage capacity	Confirm Insight database/audit and Windows log storage are sized, backed up, and offloaded so records are retained; forward security events to the SIEM. **Ext. tools:** DB/log sizing; SIEM retention review.	Audit/log storage sized and retained.	
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on audit/DB failure (alarm on stop, SIEM alert on forwarding loss); records not silently lost. **Ext. tools:** Insight DB alarms; SIEM agent-health alert.	Defined response to audit failure; alerting on loss.	
SR/CR 2.11	Timestamps	Confirm the Insight server, clients, and BACnet field time are synchronized (NTP/AD, BACnet time sync) so audit/alarm timestamps are accurate and correlate. **Ext. tools:** w32tm / NTP; BACnet time-sync review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Legacy **BACnet/IP and P2/FLN are unencrypted**; comms integrity/confidentiality are met by the compensating **VPN tunnel + firewalled zone** so field traffic is not exposed. HTTPS for any Insight web/reporting; contain cleartext BACnet inside the zone. **Ext. tools:** Wireshark (confirm field traffic tunneled/contained); VPN config.	Field comms protected by VPN/segmentation (compensating); web via HTTPS.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm the Insight host runs endpoint protection per the Siemens compatibility guidance, app allow-listing, and controlled updates so the BAS application resists malicious code. **Ext. tools:** AV/allow-list review (per Siemens compat); update review.	Application protected from malicious code (allow-listed, AV per compat).	SAR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify Insight access levels, audit, disabled FTP, VPN/firewall rules, and host hardening (STIG/CIS) against the baseline. **Ext. tools:** SCAP/STIG host scan; Insight config compare.	Security settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm database/config integrity: Insight backups, controlled configuration deployment, and change logging so unauthorized changes are prevented/detected. **Ext. tools:** Backup/deployment review; audit-log change history.	Config/database integrity protected; unauthorized change detected.	
SR/CR 3.5	Input validation	Confirm exposed services (Insight web/reporting, BACnet) tolerate malformed input without crashing; keep the host and Insight patched; fuzz only in a lab. **Ext. tools:** Patch/advisory review; BACnet/web fuzz (ISOLATED).	Patched; no crash on malformed input to exposed services.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.7	Error handling	Confirm graceful handling of faults/comm loss (redundancy/failover where used, no info leakage in errors, clean recovery). **Ext. tools:** Failover test (lab); error-handling review.	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm the compensating VPN and any HTTPS sessions are integrity-protected (TLS), replay-resistant; legacy field sessions contained by the tunnel/zone. **Ext. tools:** Wireshark (VPN/TLS session inspection).	Compensating sessions integrity-protected; field contained.	
SR/CR 3.9	Protection of audit information	Protect the Insight audit/DB and Windows logs: restricted DB/file access, forwarded to a write-once SIEM, so records cannot be altered/deleted by unauthorized users. **Ext. tools:** DB/file permission review; SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/reuse, remove the Insight database, credentials, and any exported data; sanitize the host storage (BitLocker crypto-erase / wipe) so data is not recoverable. **Ext. tools:** DB/data removal; host sanitize (see Windows sheet).	Sensitive database/data purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto on the compensating layer (VPN TLS 1.2/1.3, HTTPS for web/reporting) and that stored credentials are protected; legacy field crypto is compensated by the tunnel. **Ext. tools:** testssl.sh (VPN/HTTPS); crypto config review.	Modern crypto on the compensating layer; field via VPN.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Place the BAS in a **Protected Zone** with real Zone Boundary Protection — a **firewall is required; a separate VLAN alone does NOT meet ZBP** (per Siemens BAS cybersecurity guidance). Disable FTP; only required flows cross; remote via VPN. This is the primary compensating control for the unencrypted field protocols. **Ext. tools:** Nmap by zone; firewall rule review (confirm ZBP, not just VLAN).	BAS in a firewalled Protected Zone (VLAN alone insufficient); only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	Confirm the Insight server/clients are single-purpose: email/IM/arbitrary web removed or blocked, app allow-listing + egress filtering. **Ext. tools:** App inventory; egress/proxy review.	No general-purpose person-to-person comms on the BAS station.	
SR 5.4	Application partitioning	Confirm role separation (engineering vs operation), Insight server vs client roles, least-privilege accounts, and dedicated servers per function for high assurance. **Ext. tools:** Role/server separation review.	Roles/applications partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm Insight audit/alarms are readable/exportable and forwarded to the SIEM for continuous monitoring; the BAS zone is monitored (passive IDS). **Ext. tools:** Syslog/SIEM forwarding; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall, Insight redundancy where used, only required services exposed, connection limits; a flood does not deny BAS operation. **Ext. tools:** Firewall review; Nmap; load test (ISOLATED).	Attack surface minimized; BAS resists DoS (redundancy where used).	
SR/CR 7.2	Resource management	Confirm host/DB resource controls (CPU/memory/disk limits, DB sizing, trend/audit rotation) so one process cannot starve the Insight server. **Ext. tools:** Performance Monitor; DB/trend config review.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	Confirm the Insight database, config, and server image are backed up (versioned, offline) and restore is tested for a known-good rebuild; redundancy validated. **Ext. tools:** Backup review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: disable FTP/unused Insight options, minimize host services (per Siemens/IT-infrastructure guidance), restrict BACnet/panel endpoints. **Ext. tools:** Service/option review; Nmap (exposed services).	Least functionality; unused services disabled (FTP off) per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm Insight version, patches, options, panels/firmware, and host are inventoried so vulnerabilities track against Siemens ProductCERT advisories. **Ext. tools:** ReadOnlyEnum; Insight/panel version inventory.	Accurate software/version inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
APOGEE Insight	Identity, access levels & audit review (FR1, 2.1, 2.8)	Read Insight operator access levels, accounts/groups, and the audit/activity log; confirm least privilege.	Read/authorized copy.
SCAP/STIG (host)	Host hardening verification (3.3, 7.6)	Scan the hosting Windows Server against STIG/CIS; reference the Windows cheat sheet.	Authorized.

Tool / method	Verifies	How to use — steps / example	Constraints
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate BACnet/IP 47808, web, RDP, and confirm FTP disabled; verify only required services reachable per zone.	Read-only; authorized.
Wireshark	Comms containment review (3.1, 3.8)	Confirm legacy BACnet/P2 field traffic is tunneled (VPN) or contained inside the firewalled zone, not exposed.	Passive capture.
testssl.sh	VPN / HTTPS strength (1.8, 1.9, 4.3)	Check TLS/cipher strength on the compensating VPN and any Insight web/reporting endpoints.	Non-intrusive.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm Insight/Windows security events reach the SIEM; trigger a test event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.